

Arquitectura Web Institucionales



Antecedentes



1. La información mostrada en las páginas web es de carácter público.
2. No se tiene integración con otras aplicaciones*.
3. En los formularios de contacto se indica disclaimer de política de protección de información
4. No se guarda información de datos personales.
5. La información que se guarda en su propia base de datos está relacionada a los acuses de recibo de correos y la información propia de uso del wordpress
6. Se tiene un único servidor de base de datos y es allí donde se van creando las bases de datos para cada Web Institucional

Web Institucionales en WordPress (En proceso: Sitech):

1. Ferreyros
2. Unimaq
3. Concurso Mejor Operador
4. Asociación Ferreycorp
5. Maquicentro
6. Orvisa
7. Soltrak
8. Fargoline
9. Trex
10. Ferreycorp

***Excepción de un webhook de integración adhoc, web soltrak → bitrix, para formulario de contactos y cotización de productos.**

Diagrama de Infraestructura de Web Institucionales - Actual

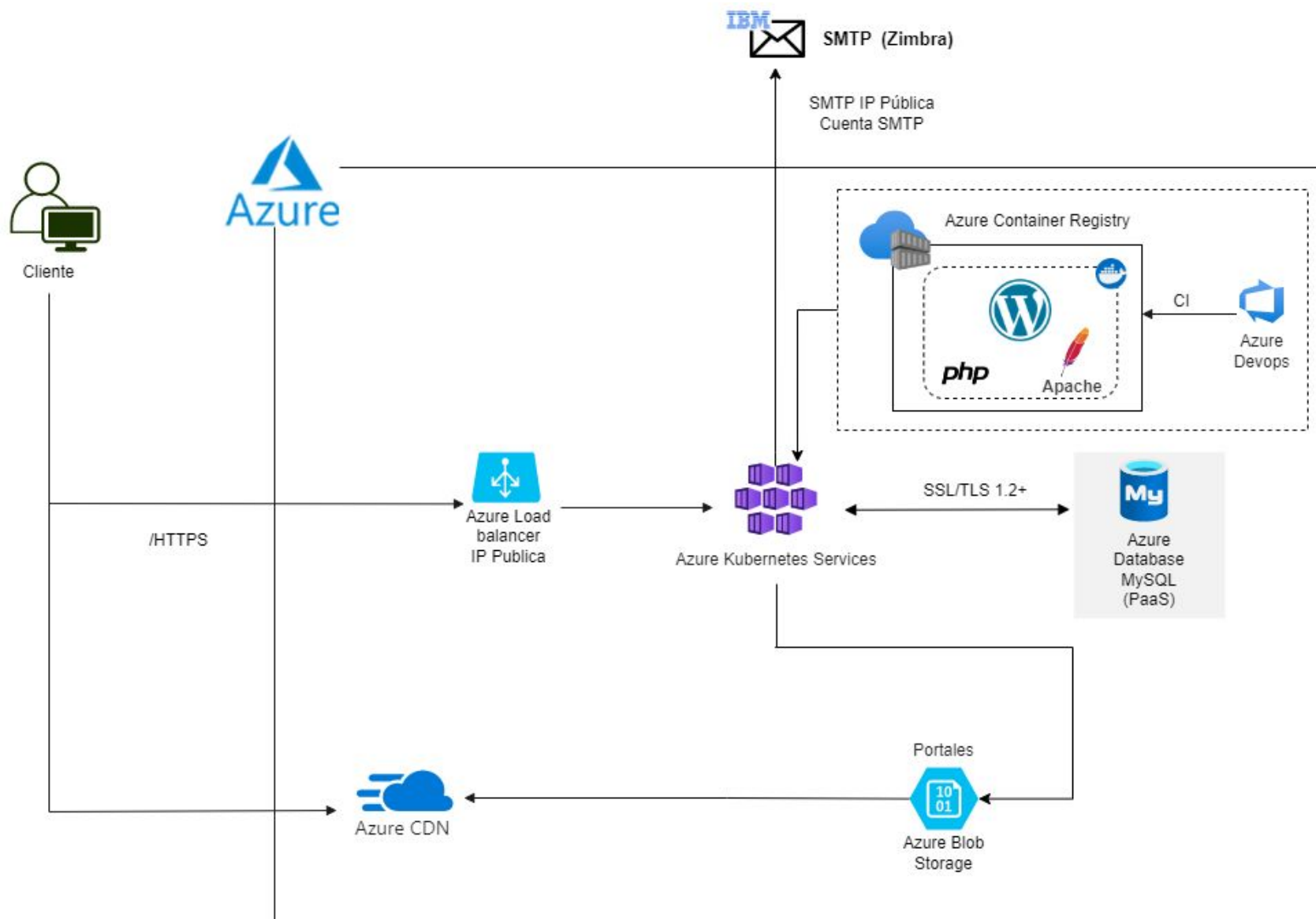
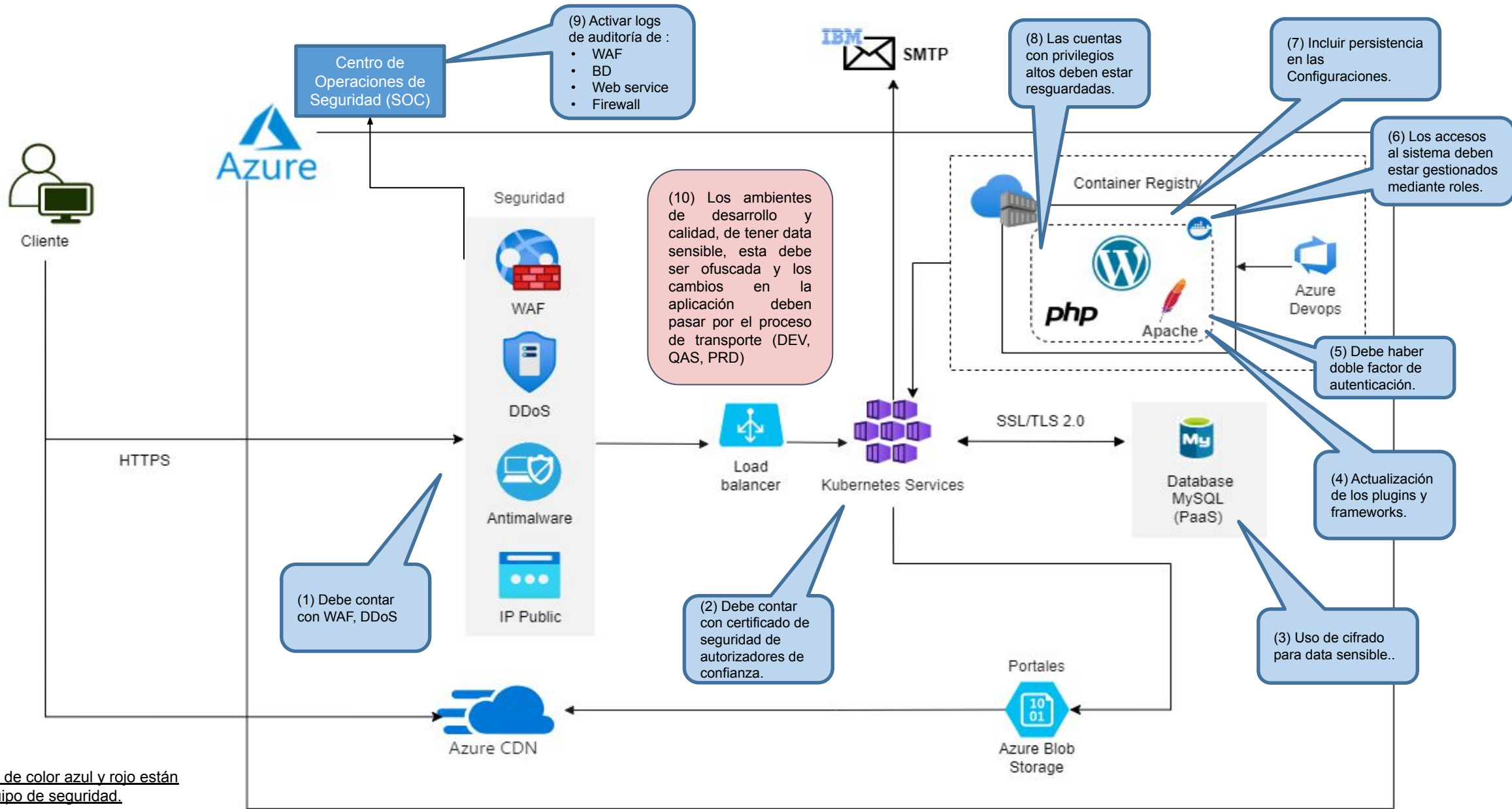


Diagrama de Infraestructura de Web Institucionales - Propuesto



*Nota: Los cuadros de color azul y rojo están incluidos por el equipo de seguridad.

Diagrama de Componentes - Web Institucionales

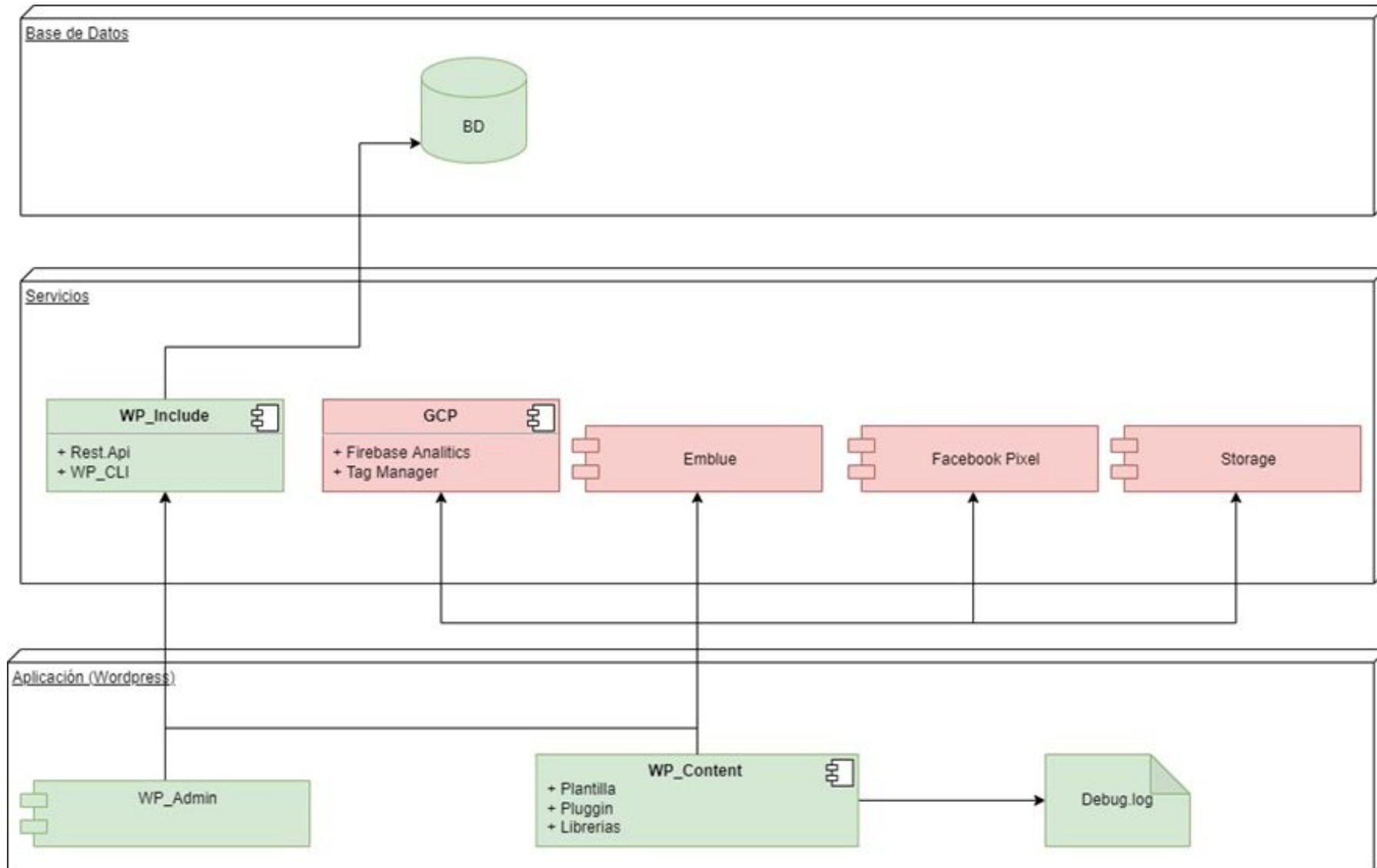


Diagrama de Infraestructura Web Institucionales - Propuesto



N°	Elemento	Responsabilidad de la Implementación en Arquitectura Propuesta
1	Provisionar WAF , DDoS, Firewall	Infraestructura
2	Entregar certificado de seguridad de autorizadores de confianza	Infraestructura
3	Cifrar la data sensible	Capítulo
4	Actualizar parches / versiones de plugins y frameworks usados	Capítulo
5	Habilitar doble factor de autenticación	Capítulo
6	Monitorear que los accesos al sistema gestionados mediante roles	Seguridad
7	Incluir persistencia en las Configuraciones	Infraestructura
8	Monitorear que cuentas con privilegios altos estén resguardadas	Seguridad
9	Activar logs de auditoría	Infraestructura
10	Ofuscar data sensible en los ambientes de desarrollo y calidad y los cambios en la aplicación deben pasar por el proceso de transporte	Capítulo

- **WAF:** Firewall de aplicaciones web, este control bloquea tráfico malicioso que trata de explotar vulnerabilidades o ejecutar inyección de código en las aplicaciones Web. Es Mandatorio en los casos en los que no se cuente con la capacidad de realizar las remediaciones de vulnerabilidades en menos de 5 días. Este control mitigará amenazas de SQL Injection, tráfico malicioso para vulnerabilidades conocidas y vulnerabilidades de día 0.
- **DDoS.** Este control bloquea los ataques de denegación de servicio distribuido, como los hecho por Botnets, estos ataques se realizan para sacar de servicio a las aplicaciones/páginas web.
- **Antimalware:** Este control prevé que los archivos que son subidos a las páginas web (ejemplo: CVs) lleguen al repositorio de datos no estructurados e infecte a todos los archivos dentro de ese repositorio.
- **Persistencia:** Deben asegurar que los archivos de configuración, que se escriban dentro del contenedor, no se pierdan al reiniciar el contenedor.
- **Centro de Operaciones de Seguridad (SOC):** Se deben activar todos los Logs de auditoría para que sean enviados y analizados por el SOC, estos deben incluir los Logs de:
 - WAF, DDBB, Web Service, Firewall (Tráfico de red entrante y saliente).
- **Firewall:** Solo debe estar público el puerto 443 de entrada, los demás deben estar cerrados; tanto entrada como salida.
- **Uso de Cifrado:** En el caso de haber información sensible o clasificado como confidencial es mandatorio encriptar los datos.
- **Actualización de las web service y el framework:** Es mandatorio tener actualizado los componentes de la aplicación web debido a que constantemente aparecen nuevas vulnerabilidades.

Estándares de Seguridad



- **Doble factor de autenticación:** Es mandatorio este método de autenticación para que un usuario pueda ingresar al sistema solo después de que presente dos o más pruebas diferentes de quién dice ser.
- **Protocolo HTTPS:** Es mandatorio utilizar un protocolo seguro para la transferencia de datos.
- **Procedimiento de transporte:** Todos los cambios en las páginas web deben pasar por un proceso de transporte de DEV pasando por QAS y llegar a PRD, con el objetivo de tener los ambientes homologados.
- **Gestión de accesos:** Los accesos al sistema deben ser gestionados mediante roles y tener la capacidad de restringir los accesos a su mínimo privilegio.

Performance Aplicaciones Web



- Toda Web Institucional debe cumplir con las métricas: **Rendimiento y Estructura**.
 - **GTmetrix Performance** es el puntaje de rendimiento de la herramienta de auditoría basada en el sitio Google Lighthouse
 - **GTmetrix Structure** es una métrica de rendimiento patentada que mide el rendimiento general de una página basada en sus elementos.
- Por tal, para poder certificar el cumplimiento de estas métricas, el puntaje con GTmetrix deberá ser 90 >=.

Métrica	Descripción	Puntaje óptimo
Largest Contentful Paint (LCP)	Es la cantidad de tiempo que tarda en cargarse la mayor parte de la página.	Debe ser menor a 1.2 segundos .
Total Blocking Time (TBT)	Es la cantidad de tiempo que una página se bloquea antes de que un usuario pueda interactuar con ella. El CSS y el JS de bloqueo de renderizado pueden tener un gran impacto en el TBT.	Debe ser menor a 150 milisegundos .
Cumulative Layout Shift (CLS)	Se refiere al desplazamiento de elementos mientras se carga una página.	El puntaje debería ser menor a 0.1 .
Speed Index	Que tan rápido los contenidos de la página son mostrados.	Debe ser menor a 1.3 segundos .
Time to interactive	Cuánto demora tu página en ser completamente interactiva.	Debe ser menor a 2.5 segundos .
First Contentful Paint	Que tan rápido contenido como texto o imágenes son pintadas en tu página	Debería ser menor a 0.9 segundos .

Puntaje	Significado
90 o superior	Experiencia de usuario positiva
Entre 50 y 90	Experiencia de usuario mejorable
Menor a 50	Experiencia de usuario negativa

Componentes



- **Azure Load Balancer**, un equilibrador de carga de capa 4 (TCP, UDP) que proporciona alta disponibilidad mediante la distribución del tráfico entrante entre máquinas virtuales.
- **Azure Kubernetes Services**, es un servicio de orquestación de contenedores robusto y rentable que ayuda a implementar y administrar aplicaciones en contenedores en segundos donde los recursos adicionales se asignan automáticamente sin el dolor de cabeza de administrar servidores adicionales.
- **Azure Container Registry**, es un servicio de registro privado para crear, almacenar y administrar imágenes de contenedores y artefactos relacionados.
- **Azure Devops**, proporciona servicios de desarrollador para permitir que los equipos planifiquen el trabajo, colaboren en el desarrollo de código y creen e implementen aplicaciones.
- **DataBase Mysql**, toda aplicación web de WordPress cuenta con esta tecnología en su capa de base de datos.
- **Azure Blob Storage**, es un servicio para almacenar grandes cantidades de datos de objetos no estructurados.
- **Azure Content Delivery Network (CDN)**, es una red distribuida de servidores que entrega de manera eficiente contenido web a los usuarios. Las CDN minimizan la latencia al almacenar el contenido en caché en servidores perimetrales en ubicaciones de punto de presencia cerca de los usuarios finales.
- **WAF**, un firewall de aplicaciones web es un tipo de firewall que supervisa, filtra o bloquea el tráfico HTTP hacia y desde una aplicación web.
- **DDoS**, ataque distribuido de denegación de servicio, es un tipo de ciberataque que intenta hacer que un sitio web o recurso de red no esté disponible colapsando con tráfico malintencionado para que no pueda funcionar correctamente.
- **IP Public**, es una dirección a la que se puede acceder directamente desde Internet y que su proveedor de servicios de Internet (ISP) asigna a su router de red.

Tecnologías	Versión Mínima a considerar
WordPress	6.3.1
PHP	8.0.0
MySQL	8.0.15
Apache	2.4.52
Apache Tomcat	9.0.54

Plugins



- Los únicos plugin autorizados, además de los plugin de SEO, para la creación de cualquier portal en la corporación son: <https://docs.google.com/document/d/1bhy87U2EDWnvynXefOI1T3SLhrUiGWT-AJQsNm2Eluk/edit?usp=sharing>; cualquier plugin adicional debe ser validado con la fábrica con su sustento respectivo.